

TechCorp Production Access Policy

RBAC, MFA, Approval & Audit Requirements

Version: v3.1

Document: TC-PAP-008

TechCorp Internal

1. Access Levels

Read-Only (L1)	View logs, metrics, dashboards. No data modification.
Operator (L2)	Deploy services, restart containers, manage config. No DB write.
DBA (L3)	Read/write access to databases. SELECT by default; DML requires ticket.
Admin (L4)	Full infrastructure access. Requires dual approval + MFA.
Emergency (L5)	Break-glass access. Self-approving but logged and reviewed within 24h.

2. RBAC Configuration

Role	AWS	Kubernetes	Database	Secrets
SRE	PowerUser	cluster-admin	Read + Operator	Read
Backend Engineer	ReadOnly + ECS	namespace-admin	Read-only	None
DBA	RDS Console only	None	Full	Read
Security	SecurityAudit	Read-only	Audit schema	Read
On-call Responder	PowerUser (timed)	cluster-admin	Read + break-glass	Read

3. MFA Requirements

- MFA is mandatory for ALL production access — no exceptions
- Approved MFA methods: hardware security key (FIDO2/WebAuthn) preferred; TOTP acceptable
- SMS OTP is forbidden — phishing risk is too high
- MFA must be re-authenticated for: new sessions, actions above current access level, AWS Console
- Lost MFA device: submit ticket to IT Security; access suspended until device verified
- Service accounts use AWS IAM roles with short-lived STS tokens — no static MFA bypass

4. Approval Process

L1 (Read)	Team lead approval — automated via Slack workflow, no ticket required
L2 (Operator)	Manager + SRE lead approval — Jira ticket required
L3 (DBA)	DBA team lead + Security — Jira ticket + justification required
L4 (Admin)	VP Engineering + Security Officer — 2 approvers required, 24h process
L5 (Break-glass)	Self-approving emergency — auto-notifies Security + VP Eng immediately
Temp Access	All temporary grants expire in 8 hours unless renewed with new approval

5. Temporary Access

- Temporary access grants are time-boxed: maximum 8 hours for L2/L3, 4 hours for L4
 - Issued via AWS IAM roles with expiring STS credentials — never permanent IAM user keys
 - All temporary access automatically revoked by automation at expiry — no manual step required
 - Extension requires new approval cycle — cannot self-extend
 - Temporary access is tagged in CloudTrail with ticket number and approver IDs
-

6. Logging

AWS Actions	CloudTrail — all API calls logged, 2-year retention
K8s Actions	Kubernetes audit logs — all kubectl commands, 90 days
DB Queries	pgAudit extension — DDL and privileged DML logged
SSH/SSM	AWS Session Manager — full session recording, 90 days
Secrets Access	AWS Secrets Manager access log — every read/write event
Login Events	Okta audit log — all SSO events, 12 months

7. Audit Rules

- Quarterly access review: all production access rights reviewed and recertified by managers
 - Automated daily check: service accounts and IAM roles not used in 90 days flagged for removal
 - Any access used outside of business hours triggers automated Slack alert to Security
 - Privileged access (L3+) actions generate weekly summary report emailed to Security team
 - Annual third-party audit of access control effectiveness required for SOC 2 compliance
-

8. Offboarding

Day 0 (Termination)	IT Security revokes all SSO access within 1 hour of HR notification
Day 0	All active sessions terminated; MFA devices de-registered
Day 1	AWS IAM users, K8s service accounts, and DB users deleted
Day 7	Confirmation audit: zero active credentials for the departed employee
Data Retention	Employee data retained per HR policy; code contributions remain
Contractor Offboarding	Same Day 0 process; access provisioned on shorter 24h notice